

ResolvX

GRC Compliance & Audit Readiness Program

Program Roadmap | v1.1

Document Type	Version	Status	Owner	Horizon
Program Roadmap	1.1	Active	GRC Lead	2026 - 2027

Roadmap Overview

The ResolvX GRC program is structured across six sequential phases. Each phase builds on the previous, creating a compounding foundation that culminates in a mature, audit-ready compliance program with a public Trust Center. Phases may partially overlap where dependencies allow.

Phase	Name	Timeline	Key Output	Status
Phase 1	Foundation	Month 1 - 2	Charter, scope, company profile, stakeholder register	✔ Complete
Phase 2	Risk & Controls	Month 2 - 4	Risk register, framework control matrix, gap analysis report	✔ Complete
Phase 3	Policies & Vendor Risk	Month 4 - 6	Policy library (8+ docs), vendor assessments, TPRM register	✔ Complete
Phase 4	Incident Response	Month 6 - 8	IR plan, runbooks, tabletop simulation report	✔ Complete
Phase 5	Audit Readiness	Month 8 - 11	Internal audit report, evidence library, corrective action plan	✔ Complete
Phase 6	Trust Center	Month 11 - 14	Public trust center, compliance dashboard, certification showcase	✔ Continuous

Phase 1 - Foundation

Objective

Establish the structural foundation for the entire GRC program. Define what ResolvX is, what it needs to protect, who owns what, and how the program will operate.

Deliverables

- Objectives, Scope & Goals document
- Program Roadmap
- Company profile and asset inventory
- Stakeholder and control owner register
- GitHub repository structure initialized

Success Criteria

- Program formally scoped with executive alignment.
- All foundational documents reviewed and version controlled.
- Repo structure established and ready for Phase 2 content.

Actual Delivery (July 2026): Delivered as planned.

Phase 2 - Risk & Controls

Objective

Build the risk management foundation. Identify, score, and prioritize ResolvX's key security risks. Map existing and planned controls to ISO 27001, SOC 2, and NIST CSF frameworks. Identify gaps.

Deliverables

- Risk register with 15+ risks, likelihood/impact scoring, heat map, mitigation owners.
- Risk methodology document.
- ISO 27001 Annex A control matrix with full 93-control mapping with status and owners.
- SOC 2 TSC criteria mapping (CC1 - CC9).
- NIST CSF 2.0 function-level mapping.
- Gap analysis report (consolidated findings across all frameworks).

Success Criteria

- All identified risks scored and assigned to owners.
- Control coverage mapped at 80%+ across SOC 2 and ISO 27001.
- Gap analysis report approved and gap remediation prioritized.

Actual Delivery (July 2026): Delivered and exceeded. Mapped 25 risks (target: 15+), mapped full 93-control ISO matrix, 44-criteria SOC 2 matrix, 103-subcategory NIST CSF matrix, gap analysis re-derived twice as the programme matured (v2.0, 2026-07-31).

Phase 3 - Policies & Vendor Risk

Objective

Translate framework requirements into actionable policies. Assess the security posture of key third-party vendors who handle ResolvX data or infrastructure.

Deliverables

- Information Security Policy
- Access Control Policy
- Incident Response Policy
- Data Classification Policy
- Vendor Management Policy
- Acceptable Use Policy
- Vendor assessment questionnaire template (25+ questions, scored)
- Vendor risk register with Tier 1 assessments completed
- Vendor risk scorecard and assessment reports

Success Criteria

- All policies reviewed, approved, and version controlled.
- 100% of Tier 1 vendors assessed with risk rating assigned.

Actual Delivery (July 2026): Massively exceeded. 26 policies delivered (POL-001 - 026). All 6 Tier 1 vendors assessed (AWS, Okta, GitHub, Google Workspace, Jamf, 1Password).

Phase 4 - Incident Response

Objective

Design, document, and test ResolvX's incident response capability. Align to ISO 27035 and NIST SP 800-61 standards.

Deliverables

- Incident Response Plan (Prepare, Detect, Contain, Eradicate, Recover, Lessons Learned)
- Runbooks for: Phishing, Ransomware, Data Breach
- Tabletop simulation scenario and facilitation guide
- Post-simulation report with findings and remediation actions

- Incident log template

Success Criteria

- IR plan covers all NIST IR lifecycle phases.
- At least one tabletop simulation completed and documented.
- All critical IR roles assigned to named owners.

Actual Delivery (July 2026): Delivered and strengthened. Conducted a Ransomware tabletop plus a new DR failover tabletop. Formulated the IR Plan.

Phase 5 - Audit Readiness

Objective

Perform a structured internal audit of all controls implemented across Phases 1 - 4. Collect evidence, identify non-conformities, and produce a corrective action plan. Simulate the experience of a SOC 2 Type II pre-audit.

Deliverables

- Internal audit checklist (Control, Evidence, Finding, Severity, Action Plan).
- Evidence library being organized by framework, with screenshots and documentation.
- Internal audit report with findings, ratings, and lessons learned.
- Corrective Action Plan (CAP) with tracked with owners and target dates.
- SOC 2 Type II readiness assessment report.

Success Criteria

- All in-scope controls tested with evidence collected or gaps documented.
- Audit report issued with severity-classified findings.
- CAP addresses all High and Critical findings.

Actual Delivery (July 2026): Delivered and re-executed. Performing continuous internal audit, CAP v1.1 (7 of 8 findings closed), SOC 2 readiness upgraded from SUBSTANTIALLY READY to FULLY READY status (17/17 criteria Ready, was 15/17).

Phase 6 - Trust Center

Objective

Synthesize the entire program into a public-facing Trust Center that demonstrates ResolvX's security and compliance posture to enterprise prospects, customers, and auditors.

Deliverables

- Compliance dashboard to showcase control coverage, risk trends, KRIs/KPIs.
- Trust Center overview page.
- Security overview document with controls, architecture, and security practices.
- Privacy and data handling overview.
- Certifications and audit reports index.
- Subprocessors and vendor list.
- Interactive trust center prototype (HTML/web artifact).

Success Criteria

- Trust center accurately reflects program maturity at program completion.
- All major certification targets and compliance milestones documented.
- Portfolio-ready showcase demonstrating end-to-end program ownership.

Key Milestones Summary

Milestone	Phase	Target
Program charter finalized	1	Month 1 :  Complete
Risk register complete	2	Month 3 :  Complete
Full control matrix mapped	2	Month 4 :  Complete
Policy library complete	3	Month 6 :  Complete
Vendor assessments complete	3	Month 6 :  Complete
IR plan tested	4	Month 8 :  Complete
Internal audit report issued	5	Month 10 :  Complete
SOC 2 readiness report complete	5	Month 11 :  Complete
Trust Center launched	6	Month 14 :  Continuous